Response to reviewers

IEEE Transactions on Network and Service Management
Manuscript TNSM 2026 12002 | Revision prepared 15 October 2026

Auditable Policy-Governed LLM-Agent Control for O-RAN Edge Security

Dear Editor and Reviewers,

Thank you for the detailed review. We have revised the manuscript to distinguish the implemented prototype, simulated action target, finite formal model and future O-RAN integration. We narrowed the semantic claims to agreement with the frozen synthetic oracle and qualified the configured LangGraph comparison. The revision adds a retained-output ablation, a phase-timing analysis of all 180 recovered benchmark reports, reproducible formal sensitivity checks, clearer operator-governance boundaries and editable workflow figures.

Updated or added manuscript text is marked in blue; clean copies are also supplied. The responses below describe completed source changes and retained evidence. No new hosted-model experiment, independent expert annotation or operational O-RAN deployment is represented as completed.

Response to the Associate Editor

The principal changes address the three concerns jointly. Sections IV-A and V and Table II clarify implementation and formal scope. Section VI-D and Table IV document the six author-designed scenarios and their limits. Sections VII-C and VII-J and Tables IX and XIII expose the comparison confounders and separate execution declarations from semantic agreement. The abstract and conclusion now make the same bounded claims. Additional validation comprises local retained-data reanalysis, formal checks and callback payload regression checks; independent expert validation, a matched inference-time ablation and live O-RAN integration remain outside the completed evidence. Reviewer-specific details follow.

Evidence available with this revision

Evidence	Verified result
Retained archives	Five earlier archive manifests plus the recovered bundle; all 180 original report packages verified. Their 3,240 file hashes and canonical report/reference joins pass. Raw metrics and clustered intervals reproduce the retained results.
Formal checks	320 original states; 480 states with zero-input probe; three mutations detect their expected invariant violations.
Regression checks	29 existing Python tests, 9 retained-evidence tests and 5 recovered-evidence tests, and 14 callback payload cases pass.
Interpretation limits	No new inference, independent annotations, real O-RAN actuation or production approval-service verification.

R1 1 Practical O RAN integration

Reviewer comment

Clarify the practical O-RAN integration. The paper positions the framework around SMO/Non-RT RIC governance, but the evaluation appears to use synthetic scenarios and simulated actuation rather than real O-RAN telemetry, rApps, A1 policies, or Near-RT RIC/xApp interactions. The authors should more clearly explain what has been implemented versus what remains architectural.

Response

We have separated the operational architecture from the evaluated prototype. Section IV-A and new Table II distinguish implemented orchestration and policy checks, simulated actuation, the finite formal model, public-testnet experiments and future interface integration. Section VI-D and Table IV identify the actual scenario fields and experimental operator-policy clauses. The live demonstration terminates at SIMULATED_O_RAN_ACTION_LEDGER with production_oran_execution=false and network_side_effects=false. No deployed rApp, standards-conformant A1 delivery, real E2 control or operator telemetry is demonstrated. The SMO/Non-RT RIC placement is therefore an intended management integration context. The abstract, claim boundary and conclusion now use that scope consistently.

Main IV-A and Table II, pp. 3–4; VI-D and Table IV, p. 6; VII-A, pp. 7–8; VIII, p. 13.

R1 2 Benchmark realism

Reviewer comment

Strengthen the benchmark realism. The 180-case frozen benchmark is useful, but it is synthetic. The paper should describe how the scenarios were generated, how representative they are of real O-RAN security operations, and whether they cover realistic ambiguity, conflicting evidence, and noisy telemetry.

Response

We have documented the construction and limits of all six author-designed configurations in Section VI-D and Table IV. The scenarios cover a compliant O-CU configuration, DRB-integrity policy conflict, legacy TLS, unauthorised xApp access, replayed evidence and missing or unsupported information. P-01–P-04 are experimental operator-policy rules, not normative O-RAN clause numbers. The canonical 180 cells cross six scenarios, three retrieval modes and ten repeats; they are not 180 independent incidents. We verified the exported input-side payloads and retained their hashes. Conflicting policy evidence and uncertainty are represented in these cases, but real noisy telemetry, systematic stale-evidence tests and an independently validated incident distribution are absent. We therefore narrowed the claims and explicitly separated the configured impairment/profile study from operational telemetry validation.

Main VI-D and Table IV, p. 6; VI-F, pp. 6–7; VII-K, p. 13; Supplement Major Revision Evidence Audit.

R1 3 Formal verification scope

Reviewer comment

Clarify the formal verification scope. The TLA+/TLC result over 320 reachable states is a useful safety check, but it verifies a finite abstraction, not the full implementation or O-RAN deployment. The paper should more explicitly state which properties are verified and which risks remain outside the model.

Response

Section V now states the exact six predicates, the seven-field state abstraction and its exclusions. We reran the unchanged model with TLC 2.19: 64 initial states and 320 reachable states, with no invariant violation. Its initialisation excludes a zero commitment. A separate, preserved zero-input probe admits that value and checks 96 initial and 480 reachable states, again without invariant violations. Three deliberate mutations each trigger the expected invariant: removing admissibility, removing the nonzero execution guard, and omitting ordinary approval for PRIVILEGED. Logs, model hashes and a reproducible runner are included. These checks establish bounded safety and sensitivity to those mutations. They do not establish liveness, cryptographic proof validity, code refinement or deployment safety. Duplicate rejection has no history variable in this model and is now confined to the appropriate runtime/contract evidence.

Main V, pp. 4–5; Supplement Formal Verification and Major Revision Evidence Audit; evidence/formal/formal_revision_checks.json.

R1 4 Operational latency

Reviewer comment

Discuss latency implications more deeply. End-to-end decision times of 80.5-109.8 seconds make the framework unsuitable for many operational security responses. The authors correctly state that this is for non-real-time management, but they should define the practical use cases where such latency is acceptable.

Response

The revised results distinguish reported decision duration from operational deadline compliance. We cite ETSI TS 103 982 V14.0.0 for Near-RT loops around 10 ms–1 s and Non-RT rApp loops above 1 s. The medians are 80.453–109.793 s and the Agentic-RAG P95 is 164.747 s, excluding later human waiting. We restrict intended tasks to deliberative compliance review, scheduled policy-change preparation and remediation planning, subject to a task-specific deadline and evidence-freshness check. We do not claim Near-RT RIC compatibility or suitability for urgent inline containment. Section VII-J and supplementary Table S15 now analyse all 180 recovered benchmark reports, with 60 timestamp records per mode. The aggregate-to-reflection phase spans the role chain and surrounding processing; its medians are 57.698, 75.637 and 79.608 s for No RAG, RAG and Agentic RAG. Four disjoint intervals sum to each internal report duration. Marginal phase medians do not sum to a median total, and parallel assessor calls are not added to wall time. This is descriptive attribution within the proposed workflow, not a causal framework/component cost. The separate S2 demonstration remains an illustrative supplementary trace. Expiry and conflict handling are stated as deployment requirements, rather than tested guarantees.

Main VII opening, p. 7; VII-A, p. 8; VII-J and Table XIII, pp. 12–13; VII-K, p. 13.

R1 5 LangGraph comparison

Reviewer comment

Clarify the comparison with LangGraph. The external LangGraph baseline is helpful, but it is not clear whether the comparison is fully fair. The authors should explain whether LangGraph received the same retrieval inputs, policy constraints, prompts, and approval logic, or whether the proposed workflow benefits from additional governance layers not available to the baseline.

Response

New Table IX reports the actual parity and differences. The canonical input-side configurations, retrieved passages and reference scoring are shared. The proposed workflow uses four requested provider aliases and a role chain; LangGraph uses one hosted assessor. Their prompts, output budgets, sampling fields, governance, timing boundaries and run dates differ. LangGraph uses a 256-token limit; the proposed OpenAI/Anthropic/Mistral requests use 5,000-token limits and omit sampling fields. The baseline latency surrounds the assessor request, while proposed values cover the returned workflow. LangGraph has no equivalent live review or ledger path. We explicitly qualify the comparison as configured workflows, withdraw framework/component-level causal attribution, and state that coverage definitions differ. The retained-output replay in VII-J is a separate limited post-processing ablation, not a matched inference-time experiment.

Main VII-C and Tables VIII–IX, pp. 8–10; VII-J, pp. 12–13; Supplement Major Revision Evidence Audit.

R1 6 Human approval and accountability

Reviewer comment

Human approval and governance need more detail. Since human approval is central to the framework, the paper should clarify the operator role, approval interface, accountability trail, and how conflicting or delayed human decisions are handled.

Response

We added two paragraphs in VII-A describing the operator role, recorded review fields, authority boundary and proposed approval view. The archived callback records identifier, claimed role, decision and rationale, linked to the run/report. Those fields do not establish cryptographic authentication. The demonstrated HUMAN approval permits one simulated write; it does not validate rejection, expiry, concurrent decisions, replay, revocation or PRIVILEGED handling. We state that a deployable service must bind the exact action/evidence version, authenticate authority and keep conflicting or stale decisions blocked. The code audit also found Boolean string coercion in the archived callback. A separate inactive V2 export now requires a real Boolean and nonempty identifiers. Local tests exercise two valid branches and twelve malformed payloads. Historical exports remain unchanged; the new export is not deployed and these tests do not verify gateway authorisation.

Main VII-A and Fig. 3, pp. 7–8; Supplement approval export repair; workflows/n8n/tnsm_revision/L4FinalPaperReviewV2.json and payload tests.

R1 7 Blockchain and testnet evidence

Reviewer comment

Avoid overclaiming blockchain/testnet evidence. The public-testnet latency results demonstrate anchoring feasibility, but they do not prove security, finality suitability, or production audit reliability. The manuscript already notes some boundaries, but this limitation should be made more prominent in the discussion.

Response

We made the evidence boundary prominent beside the anchoring results and in the implementation table. Public-testnet measurements demonstrate client-observed first inclusion for the tested bytecode/payload and RPC conditions. They do not isolate consensus effects, measure economic finality or prove production security or audit reliability. A hash can bind available content to a commitment; it does not establish telemetry truth, durable content availability, key security or reviewer authority. We also distinguish the live report's ANCHORED status and local hash chain from an externally verified receipt: the retained live report marks external-chain evidence MISSING. Public-testnet receipts belong to a separate experiment and do not prove anchoring of that live decision. The proof boundary remains explicit: the retained 240-row matrix supports no row-bound successful zero-knowledge verification.

Main IV-C, VI-F, VII-E–H and VIII; Table II; Supplement Major Revision Evidence Audit and AUTH_V2.2 Boundaries.

R1 8 Readability and organisation

Reviewer comment

Improve readability and organization. The manuscript and supplementary material are dense. A concise table separating implemented, simulated, formally verified, and future deployment components would greatly improve clarity.

Response

New Table II gives the requested component-status summary. Table IV maps the six scenarios, and Table IX makes baseline differences visible. The semantic summary, formerly Table IV and now Table VI, contains agreement and coverage only; latency remains in Fig. 4 and safety/declaration interpretation is discussed separately. We revised terminology throughout and added six primary-source related-work entries with a scope-based comparison table. Fig. S1 is now an editable functional map generated from the archived n8n JSON, with a 54-node inventory (45 computational and 9 documentation nodes); a complete editable edge-level diagram is supplied. Fig. S2 is an editable callback map. Supplement III now names the source JSON and generator and explains the six functional groups and all 49 exported connections. Their captions distinguish exported structure from observed execution. Public-testnet Table X is split into two panels to restore readable type. Reference years, volumes, pages and DOIs were reconciled with publisher metadata. An acknowledgment discloses AI assistance with revision text, scripts and reconstructed workflow figures. The marked main manuscript and supplement compile, and clean versions are supplied.

Main II, Tables I–II, IV, VI and IX; Supplement Figs. S1–S2 and Major Revision Evidence Audit; editable TikZ and draw.io files.

R2 1 Oracle relative accuracy and generality

Reviewer comment

The 180-cell evaluation is limited to six synthetic scenarios, and the oracle lacks independent expert validation. Therefore, the reported accuracy should be presented as oracle-relative, not as evidence of general O-RAN correctness; broader validation or narrower claims are needed.

Response

We adopted the narrower-claim option. The abstract, methodology, results, Fig. 4, Table VI and conclusion describe agreement with the frozen experimental oracle, rather than general O-RAN correctness. We explicitly state that six distinct author-designed scenarios have no completed independent expert validation. Ten repeats describe stability within scenario-mode conditions. All 180 reference actions require non-automatic handling (120 HUMAN, 60 NEVER), so the benchmark does not test useful autonomous execution or the full four-class distribution. We preserved the frozen oracle and verified its exported inputs, manifest and baseline joins. No independent labels or broader validation results have been invented. The existing human-validation protocol is identified as future work, including the need to amend and freeze its analysis plan before new labels are collected: action classes are nominal, so the archived linear-weighted statistic lacks a justified ordering. We have now recovered all 180 original report packages and verified their manifests (3,240 bound files plus 180 manifests). Every canonical report hash joins the previously released frozen reference. Raw reanalysis reproduces the decision/action counts, NEVER recall, coverage, whole-scenario bootstrap intervals and indexed latency statistics. The original evidence and deterministic audit script are included in the revision archive. These integrity checks do not independently authenticate provider services or validate the synthetic oracle.

Main abstract, p. 1; VI-D/Table IV, p. 6; VII-B/Table VI/Fig. 4, pp. 8–9; VII-K and VIII, p. 13.

R2 2 Ablation and the latency difference

Reviewer comment

The LangGraph comparison changes multiple architectural components simultaneously, preventing attribution of the reported gains to any single mechanism. Given the substantial latency difference (~109.8 s vs. 1.5-1.8 s), an ablation study or more qualified interpretation is needed.

Response

We have both qualified the comparison and added a limited paired replay study. Table XIII applies raw-output scoring, the archived class-consistency guard and the same guard with automatic execution disabled to identical retained outputs. On Qwen's 60 cells, execution declarations fall from 38 to zero (nine to zero on oracle-NEVER cases), while decision agreement remains 38/60 and action agreement 11/60. LangGraph remains 150/180 and 120/180 with zero declarations. The administrative execution switch uses no oracle labels. This demonstrates separation of semantics from execution declarations; it measures neither new inference quality nor latency overhead. We explicitly state that 109.793/1.843 ≈ 59.6 compares unequal workflows and timing boundaries. The recovered 180 benchmark reports also support a descriptive stage-timing analysis in supplementary Table S15. The role-chain phase medians are 57.698/75.637/79.608 s; they are not causal increments from disabling a component. A matched inference-time component study remains unavailable, so no mechanism- or framework-level causal gain is claimed.

Main VII-C/Table IX, p. 10; VII-J/Table XIII, pp. 12–13; Supplement replay and timing definitions; retained_output_ablation.csv.

R2 3 Semantic correctness and execution safety

Reviewer comment

Zero unsafe executions primarily demonstrate effective fail-closed governance, not semantic correctness. The manuscript should clearly distinguish semantic accuracy, policy behavior, and execution safety.

Response

The revision separates three outcomes: oracle-relative decision/action agreement, policy routing/coverage, and observed execution at an explicitly identified target. The raw-artifact/code audit resolves the local Qwen wording: the legacy unsafe_execution field means oracle_action_class == NEVER and final_prediction.execute == true. Neither baseline runner invokes an executor. Qwen's nine flags therefore denote erroneous declarations, not observed RAN or simulated executions; the broader count is 38 declarations on reference non-automatic cases. LangGraph has zero such flags on 180 cells. Original records are retained unchanged and the corrected interpretation is recorded in a derived report. The proposed benchmark's disabled automatic execution and the separate single approved simulated write have distinct scopes. The replay ablation shows that suppressing declarations can leave semantic errors unchanged. We no longer use a zero declaration/execution count as evidence of semantic correctness. We also corrected the proposed Agentic-RAG NEVER-class recall from 100% to 95% (19/20), recomputed from original final-action records and cross-checked against retained histograms. That recall is independent of the execute flag; the derivation and regression check are included.

Main VI-D, VII-B–D, VII-J and VIII; Tables VI–VIII and XIII; Supplement Major Revision Evidence Audit; audit_retained_revision_evidence.py.